

BÁO CÁO THỰC HÀNH BẢO MẬT ỨNG DỤNG WEB

LAB 5 · SQL INJECTION

String Concatenation · Parameter Binding · PBKDF2

Evidence-driven local security lab

Sinh viên: Lê Minh

MSSV: 21127645

Môi trường: Flask + SQLite · http://127.0.0.1:5005

Phạm vi: Dữ liệu giả lập · SELECT-only · Không kết nối Internet

Mục lục báo cáo

Chương	Nội dung	Chương	Nội dung
1	Giới thiệu	16	Prepared statement và parameter binding
2	Mục tiêu và phạm vi an toàn	17	Password hashing
3	Cơ sở lý thuyết SQL và SQLite	18	ORM và raw SQL
4	SQL Injection là gì	19	Input validation
5	Source, transform và SQL sink	20	Least privilege
6	Kiến trúc Lab05	21	Logging và monitoring
7	Database schema và dữ liệu mẫu	22	WAF và giới hạn
8	Phát hiện lỗi bằng input đơn giản	23	So sánh trước và sau vá
9	Authentication flow bình thường	24	Kết quả kiểm thử
10	Authentication logic bị thay đổi trong vulnerable mode	25	Coverage
11	Secure authentication với parameterized query và PBKDF2	26	Runtime smoke test
12	Search flow bình thường	27	Mức độ ảnh hưởng
13	Search condition bị thay đổi trong vulnerable mode	28	Phòng chống
14	Secure search với LIKE parameter	29	Bài học rút ra
15	Error handling vulnerable và secure	30	Kết luận

Danh mục sơ đồ: 4 sơ đồ tuần tự và 2 sơ đồ luồng dữ liệu Word-native. Danh mục bảng: 9 bảng trace, code comparison, test, coverage, smoke và evidence index.

Chương 1. Giới thiệu

Lab05 là ứng dụng học tập độc lập minh họa nguyên nhân SQL Injection và bản vá tại tầng xây dựng truy vấn. Báo cáo được tạo từ request, response, query event, trace, audit, log kiểm thử và source code đã tồn tại; ảnh chụp thủ công không phải dependency của báo cáo.

Chương 2. Mục tiêu và phạm vi an toàn

Runtime chỉ bind 127.0.0.1:5005, dùng SQLite nằm trong Lab05 và các scenario local cố định. Ứng dụng không nhận host, URL, port, connection string, đường dẫn database hay câu SQL tùy ý; không có scanner, UNION, blind, time-based, stacked query hoặc schema enumeration.

Chương 3. Cơ sở lý thuyết SQL và SQLite

SQL mô tả phép đọc dữ liệu theo cấu trúc do parser hiểu. SQLite là database nhúng một file, phù hợp lab local nhưng vẫn phân biệt rõ SQL text và bound value. SELECT-only không loại bỏ SQL Injection; nó chỉ giới hạn tác động ghi trong mô hình này.

Chương 4. SQL Injection là gì

SQL Injection xảy ra khi input không tin cậy tham gia cấu tạo cú pháp SQL. Trong vulnerable mode, string concatenation đặt input vào SQL text trước khi SQLite parse; trong secure mode, template và parameter đi theo hai kênh riêng.

Câu hỏi 1. SQL Injection xảy ra ở tầng nào của ứng dụng? Lỗi xuất hiện tại ranh giới xây dựng truy vấn ở tầng ứng dụng: dữ liệu không tin cậy bị ghép thành cú pháp trước khi đi vào SQL parser. SQLite chỉ thực thi văn bản mà ứng dụng đã tạo.

Chương 5. Source, transform và SQL sink

Source là request.form hoặc request.args; transform gồm normalize, legacy digest hoặc wildcard LIKE; sink là execute_read_only. Ranh giới nguy hiểm nằm ở chỗ transform bằng nối chuỗi có thể đổi cấu trúc, còn parameter binding giữ input ở vai trò dữ liệu.

Câu hỏi 13. SQL Injection khác Parameter Tampering thế nào? SQL Injection thay đổi cách SQL parser hiểu câu lệnh; Parameter Tampering thay đổi giá trị tham số nghiệp vụ nhưng không nhất thiết thay đổi cú pháp SQL.

Chương 6. Kiến trúc Lab05

Flask routes gọi validation, auth/query service, SQLite, trace và audit. Trace ID liên kết Request Inspector, Query Construction Inspector, SQL Execution Inspector, Authentication/Result Set Inspector, Database Inspector, Error Inspector, response và audit event.

Chương 7. Database schema và dữ liệu mẫu

Schema thật định nghĩa users, products, audit_logs, login_attempts, query_events và trace_records.

Seed tạo 3 user và 8 product giả lập; secure password dùng PBKDF2, còn legacy digest chỉ phục vụ luồng yếu cố ý và không được secure authentication sử dụng.

Sơ đồ luồng dữ liệu

Sơ đồ luồng dữ liệu 1. Vulnerable data flow

Untrusted Input -> Flask Request -> String Concatenation -> SQL Text -> SQLite Parser -> Unexpected Result

Bước	Node	Security meaning
1	Untrusted Input	Dữ liệu
2	Flask Request	Biến đổi/diễn giải
3	String Concatenation	Biến đổi/diễn giải
4	SQL Text	Biến đổi/diễn giải
5	SQLite Parser	Biến đổi/diễn giải
6	Unexpected Result	Biến đổi/diễn giải

Sơ đồ luồng dữ liệu 2. Secure data flow

Untrusted Input -> Flask Request -> Validation -> SQL Template -> Parameter Binding -> SQLite Parser -> Expected Result

Bước	Node	Security meaning
1	Untrusted Input	Dữ liệu
2	Flask Request	Biến đổi/diễn giải
3	Validation	Chuyển tiếp có kiểm soát
4	SQL Template	Biến đổi/diễn giải
5	Parameter Binding	Chuyển tiếp có kiểm soát
6	SQLite Parser	Biến đổi/diễn giải
7	Expected Result	Biến đổi/diễn giải

Chương 8. Phát hiện lỗi bằng input đơn giản

Quote login có quyết định query_error; quote search có quyết định query_error. Hai trace ghi Error Inspector thay vì trả traceback, full path hay thông báo SQLite chi tiết ra UI.

Chương 9. Authentication flow bình thường

Normal vulnerable login trả 1 row và quyết định authenticated. Server băm password demo bằng legacy SHA-256 rồi ghép username và digest vào câu SQL cố ý yếu.

Chương 10. Authentication logic bị thay đổi trong vulnerable mode

Input local cố định trong authentication trace tạo quyết định local_demo_bypass. Query Inspector và Final Verdict ghi nhận cấu trúc WHERE bị thay đổi; đây chỉ là hành vi của database giả lập local, không phải công cụ nhắm mục tiêu bên ngoài.

Câu hỏi 14. Authentication bypass xảy ra vì điều kiện WHERE thay đổi ra sao? Comment marker trong input local cố định làm phần kiểm tra digest phía sau không còn tham gia điều kiện cuối; bản ghi đầu tiên phù hợp có thể được trả về.

Chương 11. Secure authentication với parameterized query và PBKDF2

Cùng input trong secure trace có quyết định rejected. Lookup dùng WHERE username = ?, sau đó check_password_hash xác minh PBKDF2 và chỉ tạo session khi verifier thành công; lỗi trả thông báo credential chung.

Chương 12. Search flow bình thường

Normal vulnerable search trả 2 row từ products. Luồng bình thường cho thấy chức năng hợp lệ trước khi so sánh với quote và expanded scenario.

Chương 13. Search condition bị thay đổi trong vulnerable mode

Expanded vulnerable search trả 8 row và quyết định unexpected_results. Result Set Inspector xác nhận chỉ products được đọc, không truy cập users và không thay đổi database.

Chương 14. Secure search với LIKE parameter

Secure search với cùng input trả 0 row và quyết định expected_results; normal secure search trả 2 row với quyết định expected_results. SQL giữ LIKE ? và LIMIT 50; wildcard là một phần của bound parameter thay vì SQL text.

Chương 15. Error handling vulnerable và secure

Vulnerable error evidence giữ exception category và nguyên nhân kỹ thuật đã rút gọn cho Inspector. Secure route xem dấu nháy là dữ liệu và không lộ SQLite detail; cả hai đường đều không lộ traceback hoặc absolute database path.

Câu hỏi 5. Vì sao không hiển thị lỗi SQL chi tiết cho người dùng? Thông báo chi tiết có thể lộ dialect, tên bảng, cột, đường dẫn hoặc cấu trúc truy vấn. UI chỉ trả thông báo chung; chi tiết đã rút gọn dành cho audit local.

Sơ đồ tuần tự từ trace thật

Sơ đồ tuần tự 1. Vulnerable login

User	Browser	Flask	Query Builder	SQLite	Password Verifier	Session
actor	actor	actor	actor	actor	actor	actor
STT	From -> To	Message	Observed evidence			
1	User -> Browser	Submit fixed local input	admin_lab' --			
2	Browser -> Flask	POST /vulnerable/login	55c89316764146ae9e43f5c4efcabaa0			
3	Flask -> Query Builder	string_concatenation	SELECT id, username, display_name, role FROM users WHERE username = '<username_inp...			
4	Query Builder -> SQLite	Execute SELECT	SELECT id, username, display_name, role FROM users WHERE username = 'admin_lab' --...			
5	SQLite -> Flask	Return result/error	rows=1			
6	Flask -> Password Verifier	Verify only in secure mode	True			
7	Flask -> Session	Create only after allow	True			
8	Flask -> Browser	Safe response	local_demo_bypass			

Sơ đồ tuần tự 2. Secure login

User	Browser	Flask	Query Builder	SQLite	Password Verifier	Session
actor	actor	actor	actor	actor	actor	actor
STT	From -> To	Message	Observed evidence			
1	User -> Browser	Submit fixed local input	admin_lab' --			
2	Browser -> Flask	POST /secure/login	8a4e0745249948a196da1014e26512c9			
3	Flask -> Query Builder	parameter_binding	SELECT id, username, display_name, role, password_hash FROM users WHERE username =...			
4	Query Builder -> SQLite	Execute SELECT	SELECT id, username, display_name, role, password_hash FROM users WHERE username =...			
5	SQLite -> Flask	Return result/error	rows=0			
6	Flask -> Password Verifier	Verify only in secure mode	False			
7	Flask -> Session	Create only after allow	False			
8	Flask -> Browser	Safe response	rejected			

Sơ đồ tuần tự 3. Vulnerable search

User	Browser	Flask	Query Builder	SQLite	Password Verifier	Session
actor	actor	actor	actor	actor	actor	actor
STT	From -> To	Message	Observed evidence			
1	User -> Browser	Submit fixed local input	% ' OR 1=1 --			
2	Browser -> Flask	GET /vulnerable/search	8e1fc920adab463c94cdb1a947361509			
3	Flask -> Query Builder	string_concatenation	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND na...			
4	Query Builder -> SQLite	Execute SELECT	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND na...			
5	SQLite -> Flask	Return result/error	rows=8			
6	Flask -> Browser	Safe response	unexpected_results			

Sơ đồ tuần tự 4. Secure search

User	Browser	Flask	Query Builder	SQLite	Password Verifier	Session
actor	actor	actor	actor	actor	actor	actor
STT	From -> To	Message	Observed evidence			
1	User -> Browser	Submit fixed local input	% ' OR 1=1 --			
2	Browser -> Flask	GET /secure/search	9b0a0f174a1445f498db308da2bfc5dd			
3	Flask -> Query Builder	parameter_binding	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND na...			
4	Query Builder -> SQLite	Execute SELECT	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND na...			
5	SQLite -> Flask	Return result/error	rows=0			
6	Flask -> Browser	Safe response	expected_results			

Chương 16. Prepared statement và parameter binding

Prepared statement tách bước compile/parse template khỏi giá trị. sqlite3 placeholder ? và tuple parameters là cơ chế thật được dùng; không có replace, manual escaping hoặc parameterized query giả.

Câu hỏi 2. Vì sao escaping thủ công dễ sai? Escaping thủ công phụ thuộc ngữ cảnh, encoding và dialect; chỉ một trường hợp bị bỏ sót cũng làm dữ liệu trở lại thành cú pháp. Parameter binding giao việc phân tách mã và dữ liệu cho driver.

Câu hỏi 3. Prepared statement khác nối chuỗi SQL như thế nào? Nối chuỗi tạo một văn bản SQL mới từ input. Prepared statement giữ template SQL cố định và truyền giá trị qua kênh parameter riêng.

Câu hỏi 9. Parameterized query xử lý dấu nháy đơn ra sao? Driver mã hóa dấu nháy như một phần của giá trị bound; dấu này không đóng literal và không đổi cây cú pháp của câu lệnh.

Chương 17. Password hashing

Werkzeug generate_password_hash dùng pbkdf2:sha256:600000 với salt; check_password_hash thực hiện verifier. Database Inspector chỉ được phép trình bày thuật toán, độ dài và fingerprint rút gọn, không đưa full hash vào báo cáo.

Câu hỏi 7. Vì sao password phải dùng PBKDF2, bcrypt hoặc Argon2? Các hàm này có salt và chi phí tính toán điều chỉnh được, làm chậm thử đoán hàng loạt. Hàm băm nhanh không có thuộc tính này.

Câu hỏi 8. Vì sao SHA-256 không salt không phù hợp lưu password? Cùng password sinh cùng digest, hỗ trợ bằng tra cứu và thử đoán tốc độ cao. Lab chỉ giữ digest legacy để minh họa mô hình cũ cố ý yếu.

Câu hỏi 12. Vì sao không lưu plaintext password? Lộ database sẽ lộ ngay credential và tạo nguy cơ tái sử dụng trên hệ thống khác. Chỉ verifier có salt và chi phí phù hợp được lưu.

Chương 18. ORM và raw SQL

Lab không thêm ORM vì sqlite3 parameter binding đã đáp ứng phạm vi. ORM chỉ an toàn khi API tạo bound parameters; raw SQL, dynamic identifier hoặc literal fragment vẫn cần review như SQL viết tay.

Câu hỏi 4. ORM có tự động chống SQL Injection trong mọi trường hợp không? Không. ORM an toàn khi dùng API parameterized đúng cách; raw fragments, dynamic identifiers và escape tự chế vẫn có thể tái tạo lỗ hổng.

Chương 19. Input validation

Validation giới hạn độ dài, kiểu integer và chỉ cho phép scenario cố định ở route vulnerable. User detail vulnerable có quyết định found; secure user detail validate integer, bind placeholder và có quyết định found. Validation giảm bề mặt nhưng bản vá cấu trúc vẫn là parameter binding.

Câu hỏi 6. Vì sao input validation không thay thế prepared statement? Validation kiểm soát định dạng nghiệp vụ, còn parameter binding bảo vệ cấu trúc SQL. Một giá trị hợp lệ về nghiệp vụ vẫn có thể chứa ký tự đặc biệt, nên cần cả hai lớp.

Chương 20. Least privilege

SQLite không có user/role permission model như server database. Lab mô phỏng least privilege trung thực bằng file local, process non-root trong Docker, query định nghĩa sẵn, SELECT-only cho input và không cung cấp database path hay connection string.

Câu hỏi 11. Least privilege giảm tác động ra sao? Giới hạn quyền, câu lệnh và dữ liệu truy cập làm giảm phạm vi hậu quả nếu một truy vấn bị điều khiển. SQLite lab mô phỏng bằng process non-root, file local và SELECT định nghĩa sẵn.

Chương 21. Logging và monitoring

Audit evidence có 18 record liên kết trace_id; query evidence có 10 record. Log giữ template, parameter count, decision, reason, row count và error category, đồng thời redaction password và digest đầy đủ.

Câu hỏi 15. Vì sao log không được chứa password hoặc full query nhạy cảm? Log thường được sao chép và giữ lâu. Password, hash đầy đủ hoặc truy vấn chứa secret sẽ biến hệ thống quan sát thành nguồn rò rỉ thứ hai.

Chương 22. WAF và giới hạn

WAF có thể phát hiện pattern phổ biến nhưng không hiểu đầy đủ ngữ cảnh code và có thể bị né tránh. Nó là lớp hỗ trợ cho monitoring; không thay thế parameterized query, password hashing, validation, least privilege và error handling.

Câu hỏi 10. Vì sao WAF không thay thế sửa code? WAF chỉ là lớp lọc hỗ trợ và có thể bị bypass hoặc gây false positive. Bản và gốc phải loại bỏ khả năng input trở thành cú pháp bằng parameter binding.

Chương 23. So sánh trước và sau vá

Code Comparison dưới đây được trích bằng ast.parse từ function đang chạy. Bản vulnerable nối input vào SQL; bản secure giữ SQL constant, truyền tuple parameter và tách password verification khỏi truy vấn.

Code Comparison trích từ source thật

File	Function	Lines	Source excerpt
vulnerable_queries.py	vulnerable_login	18-35	def vulnerable_login(username: str, password: str) -> tuple[list, dict]: digest = legacy_digest(password) sql = ("SELECT id, username, display_name, role FROM users " f"WHERE username = '{username}' AND legacy_password_digest = '{digest}'") started = perf_counter() try: rows = execute_read_only(sql) error = None except Exce...
secure_queries.py	secure_login_lookup	28-29	def secure_login_lookup(username: str) -> tuple[list, dict]: return _run("login", LOGIN_SQL, (username,))
auth_service.py	authenticate_secure	28-39	def authenticate_secure(username: str, password: str) -> dict: rows, query = secure_login_lookup(username) row = rows[0] if rows else None verified = bool(row and check_password_hash(row["password_hash"], password)) user = {(key: row[key] for key in ("id", "username", "display_name", "role")) if verified else None) return { "..."
vulnerable_queries.py	vulnerable_search	38-54	def vulnerable_search(keyword: str) -> tuple[list, dict]: sql = ("SELECT id, name, category, price_vnd, stock FROM products " f"WHERE visible = 1 AND name LIKE '%{keyword}%'") started = perf_counter() try: rows = execute_read_only(sql) error = None except Exception as exc: rows, error = [], exc return rows, { "feature": "se..."
secure_queries.py	secure_search	32-33	def secure_search(keyword: str) -> tuple[list, dict]: return _run("search", SEARCH_SQL, (f"%{keyword}%"))
validation.py	validate_username	17-26	def validate_username(value: str None, *, vulnerable: bool = False) -> str: username = value or "" if vulnerable and username in {QUOTE_INPUT, AUTH_LOGIC_INPUT}: return username username = username.strip() if not username or len(username) > 64: raise ValidationError("Username length must be between 1 and 64 characters.") if...
error_service.py	error_inspector	23-43	def error_inspector(error: Exception, *, secure: bool) -> dict: error_id = uuid.uuid4().hex[:12] category = categorize_database_error(error) if secure: return { "error_id": error_id, "category": category, "handled": True, "user_message": "Không thể xử lý yêu cầu.", "internal_log_location": "evidence/logs/errors.log", } shorte...

Chương 24. Kết quả kiểm thử

pytest.txt ghi 230 passed, 0 failed và 0 errors; trạng thái dẫn xuất là passed. Báo cáo không tự đổi kết quả này thành thành công nếu log có failure.

Chương 25. Coverage

coverage.txt có 9 dòng module parse được; TOTAL là 99%. Các giá trị trong bảng coverage được đọc trực tiếp từ log, không ghi cứng.

Module	Coverage %	Nguồn
audit_service.py	100	Observed
auth_service.py	100	Observed
database.py	95	Observed
error_service.py	100	Observed
secure_queries.py	100	Observed
trace_service.py	100	Observed
validation.py	100	Observed
vulnerable_queries.py	100	Observed
TOTAL	99	Observed

Chương 26. Runtime smoke test

Runtime smoke evidence có 12 PASS và 0 FAIL; trạng thái dẫn xuất là passed. Smoke chỉ gọi loopback và không thay thế quyết định SameSite hoặc hành vi trình duyệt thực.

PASS	FAIL	Status
12	0	passed

Chương 27. Mức độ ảnh hưởng

Trong hệ thống thật, SQL Injection có thể dẫn đến đọc trái phép, bypass authentication, sửa/xóa dữ liệu hoặc leo thang tùy quyền database. Lab thu hẹp thành SELECT local để quan sát nguyên nhân mà không mở rộng năng lực tấn công.

Chương 28. Phòng chống

Phòng chống ưu tiên parameter binding ở mọi giá trị, allowlist cho identifier không bind được, PBKDF2/bcrypt/Argon2 cho password, error chung, least privilege, audit có redaction, review raw SQL và kiểm thử regression qua public route.

Chương 29. Bài học rút ra

Bài học chính là validation, WAF và ORM không thể bù cho truy vấn nối chuỗi. Evidence tốt phải liên kết request -> trace -> query -> audit -> response và chỉ kết luận từ flow đã chạy.

Chương 30. Kết luận

Lab05 chứng minh cùng input có ý nghĩa khác nhau tùy construction method: vulnerable SQL có thể đổi logic hoặc lỗi parse, còn secure SQL giữ cấu trúc. Bản vá là parameter binding kết hợp PBKDF2, safe errors, least privilege và monitoring.

Phụ lục A. Evidence và lệnh tái lập

Loại	Số lượng	Nguồn thật
Trace JSON	12	evidence/traces/*.json
Request	10	evidence/requests/*.txt
Response	10	evidence/responses/*.txt
Query evidence	10	evidence/queries/*.json
Audit event	18	evidence/audit/audit_logs.json
Code snippets	7	AST extraction from current source
Lệnh chạy	5	seed.py; pytest; coverage; runtime smoke; generate_report.py

Lệnh tái lập: python seed.py; python -m pytest; python -m pytest --cov=. --cov-report=term-missing; python scripts/run_runtime_smoke_test.py; python scripts/generate_report.py.

Phụ lục Trace 1. Normal vulnerable login

Trace ID: 2dc5d5fe0bb24141a94e17da83b5587f · Mode: vulnerable · Feature: login · Decision: authenticated

Field	Observed value	Field	Observed value
Mục tiêu	Xác nhận credential demo hợp lệ đi qua luồng legacy cố ý yếu.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	admin_lab	Request	Method: POST Full URL: http://127.0.0.1:5005/vulnerable/login Path: /vulnerable/login Query string: - Content-Type: application...
Source/normalize	request.form -> admin_lab	Query template	SELECT id, username, display_name, role FROM users WHERE username = '<username_input>' AND legacy_password_digest = '<password_...
Construction	string_concatenation	Final query masked	SELECT id, username, display_name, role FROM users WHERE username = 'admin_lab' AND legacy_password_digest = '[REDACTED]'
SQLite	syntax-capable text	Rows	1
Decision	authenticated	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	expected local result	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	2dc5d5fe0bb24141a94e17da83b5587f
Audit event	{"action": "login_normal_success", "decision": "authenticated", "reason": "legacy_digest_matched", "trace_id": "2dc5d5fe0bb24141a... ...	Final verdict	{"feature": "login", "mode": "vulnerable", "input_category": "normal", "query_construction": "string_concatenation", "sql_structure_c hạ...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Credentials submitted	form submission	{"value": "admin_lab"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	HTTP Request	POST created	HTTP form encoding	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Flask Router	Form read	request parsing	{"value": "admin_lab"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Input Validation	Length checked	trust-boundary validation	{"value": "admin_lab"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	Password Processing	Legacy digest created	legacy digest	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
6	Query Construction	SQL concatenated	string concatenation	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
7	Query Construction	SQL structure evaluated	SQL structure change	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
8	SQLite Parser	Final SQL parsed	SQL parsing	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
9	SQLite Execution	Result set returned	local SQLite SELECT	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
10	Authentication Decision	First row evaluated	legacy authentication decision	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
11	Session Management	Session decision	local demo session	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data
12	Final Result	Security verdict	security verdict	{"value": "[observed]"}	{"decision": "authenticated", "error_c atego...	vulnerable_queries.py	observed	SQL structure is not isolated from data

Phụ lục Trace 2. Quote login

Trace ID: 2b08975c1bc14729893a3248ce13af54 · Mode: vulnerable · Feature: login · Decision: query_error

Field	Observed value	Field	Observed value
Mục tiêu	Quan sát dấu nhảy đơn làm hỏng SQL nối chuỗi mà không lộ traceback.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	,	Request	Method: POST Full URL: http://127.0.0.1:5005/vulnerable/login Path: /vulnerable/login Query string: - Content-Type: application...
Source/normalize	request.form -> '	Query template	SELECT id, username, display_name, role FROM users WHERE username = '<username_input>' AND legacy_password_digest = '<password_...
Construction	string_concatenation	Final query masked	SELECT id, username, display_name, role FROM users WHERE username = '' AND legacy_password_digest = '[REDACTED]'
SQLite	syntax-capable text	Rows	0
Decision	query_error	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	query error observed	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	2b08975c1bc14729893a3248ce13af54
Audit event	{ "action": "login_quote_detected", "decision": "query_error", "reason": "sqlite_rejected_final_sql", "trace_id": "2b08975c1bc1472..."	Final verdict	{ "feature": "login", "mode": "vulnerable", "input_category": "fixed_test", "query_construction": "string_concatenation", "sql_structur e...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Credentials submitted	form submission	{"value":""}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	HTTP Request	POST created	HTTP form encoding	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Flask Router	Form read	request parsing	{"value":""}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Input Validation	Length checked	trust-boundary validation	{"value":""}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	Password Processing	Legacy digest created	legacy digest	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
6	Query Construction	SQL concatenated	string concatenation	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
7	Query Construction	SQL structure evaluated	SQL structure change	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
8	SQLite Parser	Final SQL parsed	SQL parsing	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
9	SQLite Execution	Result set returned	local SQLite SELECT	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
10	Authentication Decision	First row evaluated	legacy authentication decision	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
11	Session Management	Session decision	local demo session	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data
12	Final Result	Security verdict	security verdict	{"value":"[observed]"}	{"decision":"query_error","error_cat egory..."	vulnerable_queries.py	error	SQL structure is not isolated from data

Phụ lục Trace 3. Local authentication logic demonstration

Trace ID: 55c89316764146ae9e43f5c4efcabaa0 · Mode: vulnerable · Feature: login · Decision: local_demo_bypass

Field	Observed value	Field	Observed value
Mục tiêu	Chứng minh input local cố định làm thay đổi điều kiện WHERE.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	admin_lab' --	Request	Method: POST Full URL: http://127.0.0.1:5005/vulnerable/login Path: /vulnerable/login Query string: - Content-Type: application/...
Source/normalize	request.form -> admin_lab' --	Query template	SELECT id, username, display_name, role FROM users WHERE username = '<username_input>' AND legacy_password_digest = '<password_...>'
Construction	string_concatenation	Final query masked	SELECT id, username, display_name, role FROM users WHERE username = 'admin_lab' -- ' AND legacy_password_digest = '[REDACTED]'
SQLite	syntax-capable text	Rows	1
Decision	local_demo_bypass	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	authentication bypass	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	55c89316764146ae9e43f5c4efcabaa0
Audit event	{"action":"login_logic_changed","decision":"local_demo_bypass","reason":"fixed_local_input_changed_where_logic","trace_id"..	Final verdict	{"feature":"login","mode":"vulnerable","input_category":"fixed_test","query_construction":"string_concatenation","sql_structur e...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Credentials submitted	form submission	{"value":"admin_lab' --"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	HTTP Request	POST created	HTTP form encoding	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Flask Router	Form read	request parsing	{"value":"admin_lab' --"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Input Validation	Length checked	trust-boundary validation	{"value":"admin_lab' --"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	Password Processing	Legacy digest created	legacy digest	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
6	Query Construction	SQL concatenated	string concatenation	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
7	Query Construction	SQL structure evaluated	SQL structure change	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
8	SQLite Parser	Final SQL parsed	SQL parsing	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
9	SQLite Execution	Result set returned	local SQLite SELECT	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
10	Authentication Decision	First row evaluated	legacy authentication decision	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
11	Session Management	Session decision	local demo session	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data
12	Final Result	Security verdict	security verdict	{"value":"[observed]"}	{"decision":"local_demo_bypass","error_ca...	vulnerable_queries.py	observed	SQL structure is not isolated from data

Phụ lục Trace 4. Secure rejection

Trace ID: 8a4e0745249948a196da1014e26512c9 · Mode: secure · Feature: login · Decision: rejected

Field	Observed value	Field	Observed value
Mục tiêu	Chứng minh cùng input chỉ là dữ liệu khi bind parameter.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	admin_lab' --	Request	Method: POST Full URL: http://127.0.0.1:5005/secure/login Path: /secure/login Query string: - Content-Type: application/x-www-f...
Source/normalize	request.form -> admin_lab' --	Query template	SELECT id, username, display_name, role, password_hash FROM users WHERE username = ? AND active = 1 LIMIT 1
Construction	parameter_binding	Final query masked	SELECT id, username, display_name, role, password_hash FROM users WHERE username = ? AND active = 1 LIMIT 1
SQLite	data	Rows	0
Decision	rejected	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	none observed
Impact	expected local result	Code vulnerable/secure	secure_queries.py
Bản vá	Dùng SQL template + parameter binding; login secure tách PBKDF2 verification.	Trace JSON	8a4e0745249948a196da1014e26512c9
Audit event	{"action":"secure_login_rejected","decision":"rejected","reason":"invalid_credentials","trace_id":"8a4e0745249948a196da101...	Final verdict	{"feature":"login","mode":"secure","input_category":"fixed_test","query_construction":"parameter_binding","sql_structure_cha nge...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Credentials submitted	form submission	{"value":"admin_lab' --"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
2	Input Validation	Length checked	trust-boundary validation	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
3	Query Construction	Template selected	prepared statement	{"value":"admin_lab' --"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
4	Query Construction	Username bound	parameter binding	{"value":"admin_lab' --"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
5	SQLite Execution	Exact user lookup	parameterized SELECT	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
6	Password Processing	PBKDF2 verified	PBKDF2 verification	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
7	Authentication Decision	Decision made	generic authentication decision	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
8	Session Management	Session decision	session rotation	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
9	Audit Logging	Event recorded	redacted audit logging	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data
10	Final Result	Security verdict	security verdict	{"value":"[observed]"}	{"decision":"rejected","error_catego ry":"n..."}	secure_queries.py	observed	Input remains data

Phụ lục Trace 5. Secure normal login

Trace ID: 3b987d64e0464cbb8d8092e4c40067d5 · Mode: secure · Feature: login · Decision: authenticated

Field	Observed value	Field	Observed value
Mục tiêu	Xác nhận lookup bằng placeholder và PBKDF2 cho credential hợp lệ.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	admin_lab	Request	Method: POST Full URL: http://127.0.0.1:5005/secure/login Path: /secure/login Query string: - Content-Type: application/x-www-f...
Source/normalize	request.form -> admin_lab	Query template	SELECT id, username, display_name, role, password_hash FROM users WHERE username = ? AND active = 1 LIMIT 1
Construction	parameter_binding	Final query masked	SELECT id, username, display_name, role, password_hash FROM users WHERE username = ? AND active = 1 LIMIT 1
SQLite	data	Rows	1
Decision	authenticated	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	none observed
Impact	expected local result	Code vulnerable/secure	secure_queries.py
Bản vá	Dùng SQL template + parameter binding; login secure tách PBKDF2 verification.	Trace JSON	3b987d64e0464cbb8d8092e4c40067d5
Audit event	{"action":"secure_login_success","decision":"authenticated","reason":"pbkdf2_verified","trace_id":"3b987d64e0464cbb8d8092e...}	Final verdict	{"feature":"login","mode":"secure","input_category":"normal","query_construction":"parameter_binding","sql_structure_chang...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Credentials submitted	form submission	{"value":"admin_lab"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
2	Input Validation	Length checked	trust-boundary validation	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
3	Query Construction	Template selected	prepared statement	{"value":"admin_lab"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
4	Query Construction	Username bound	parameter binding	{"value":"admin_lab"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
5	SQLite Execution	Exact user lookup	parameterized SELECT	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
6	Password Processing	PBKDF2 verified	PBKDF2 verification	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
7	Authentication Decision	Decision made	generic authentication decision	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
8	Session Management	Session decision	session rotation	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
9	Audit Logging	Event recorded	redacted audit logging	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data
10	Final Result	Security verdict	security verdict	{"value":"[observed]"}	{"decision":"authenticated","error_catego...	secure_queries.py	observed	Input remains data

Phụ lục Trace 6. Normal vulnerable search

Trace ID: a2c1d998c8ec47c7b3814cf74704f91b · Mode: vulnerable · Feature: search · Decision: expected_results

Field	Observed value	Field	Observed value
Mục tiêu	Xác nhận tìm kiếm bình thường trong bảng products local.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	USB	Request	Method: GET Full URL: http://127.0.0.1:5005/vulnerable/search?keyword=USB Path: /vulnerable/search Query string: keyword=USB Co...
Source/normalize	request.args -> USB	Query template	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%<keyword>%'
Construction	string_concatenation	Final query masked	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%USB%'
SQLite	syntax-capable text	Rows	2
Decision	expected_results	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	expected local result	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	a2c1d998c8ec47c7b3814cf74704f91b
Audit event	{"action":"search_normal","decision":"expected_results","reason":"result_set_compared_with_expected_filter","trace_id":"a2...	Final verdict	{"feature":"search","mode":"vulnerable","input_category":"normal","query_construction":"string_concatenation","sql_structure_ch...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Keyword submitted	query string submission	{"value":"USB"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	Flask Router	Query string read	request parsing	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Query Construction	Keyword concatenated	string concatenation	{"value":"USB"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Query Construction	Final SQL created	SQL structure change	{"value":"USB"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	SQLite Parser	Final SQL parsed	SQL parsing	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
6	SQLite Execution	Read-only SELECT	local SQLite SELECT	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
7	Result Set	Condition compared	result comparison	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
8	HTTP Response	Results rendered	safe rendering	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data
9	Final Result	Security verdict	security verdict	{"value":"[observed]"}	{"decision":"expected_results","error_cat...	vulnerable_queries.py	observed	SQL structure is not isolated from data

Phụ lục Trace 7. Quote search

Trace ID: f6613e961ae548cebe4cc7e5f3f5f346 · Mode: vulnerable · Feature: search · Decision: query_error

Field	Observed value	Field	Observed value
Mục tiêu	Quan sát lỗi cú pháp do dấu nhảy trong chuỗi LIKE nổi trực tiếp.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	,	Request	Method: GET Full URL: http://127.0.0.1:5005/vulnerable/search?keyword=' Path: /vulnerable/search Query string: keyword=' Conten...
Source/normalize	request.args -> '	Query template	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%<keyword>%'
Construction	string_concatenation	Final query masked	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%"'
SQLite	syntax-capable text	Rows	0
Decision	query_error	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	query error observed	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	f6613e961ae548cebe4cc7e5f3f5f346
Audit event	{"action": "search_quote_detected", "decision": "query_error", "reason": "sqlite_rejected_final_sql", "trace_id": "f6613e961ae548...	Final verdict	{"feature": "search", "mode": "vulnerable", "input_category": "fixed_test", "query_construction": "string_concatenation", "sql_struct ur...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Keyword submitted	query string submission	{"value": ""}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	Flask Router	Query string read	request parsing	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Query Construction	Keyword concatenated	string concatenation	{"value": ""}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Query Construction	Final SQL created	SQL structure change	{"value": ""}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	SQLite Parser	Final SQL parsed	SQL parsing	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	error	SQL structure is not isolated from data
6	SQLite Execution	Read-only SELECT	local SQLite SELECT	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	error	SQL structure is not isolated from data
7	Result Set	Condition compared	result comparison	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	error	SQL structure is not isolated from data
8	HTTP Response	Results rendered	safe rendering	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	error	SQL structure is not isolated from data
9	Final Result	Security verdict	security verdict	{"value": "[observed]"}	{"decision": "query_error", "error_cat egory...	vulnerable_queries.py	error	SQL structure is not isolated from data

Phụ lục Trace 8. Expanded vulnerable search

Trace ID: 8e1fc920adab463c94cdb1a947361509 · Mode: vulnerable · Feature: search · Decision: unexpected_results

Field	Observed value	Field	Observed value
Mục tiêu	Chứng minh điều kiện tìm kiếm bị mở rộng nhưng chỉ đọc products.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	%' OR 1=1 --	Request	Method: GET Full URL: http://127.0.0.1:5005/vulnerable/search?keyword=%25'+OR+1%3D1+--+ Path: /vulnerable/search Query string: ...
Source/normalize	request.args -> %' OR 1=1 --	Query template	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%<keyword>%'
Construction	string_concatenation	Final query masked	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE '%"%' OR 1=1 -- %'
SQLite	syntax-capable text	Rows	8
Decision	unexpected_results	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	SQL string concatenation
Impact	unexpected product rows	Code vulnerable/secure	vulnerable_queries.py
Bản vá	Đối chiếu secure flow dùng parameter binding và safe error.	Trace JSON	8e1fc920adab463c94cdb1a947361509
Audit event	{"action":"search_condition_changed","decision":"unexpected_results","reason":"result_set_compared_with_expected_filter","..	Final verdict	{"feature":"search","mode":"vulnerable","input_category":"fixed_test","query_construction":"string_concatenation","sql_struct

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Keyword submitted	query string submission	{"value": "%' OR 1=1 -- "}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
2	Flask Router	Query string read	request parsing	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
3	Query Construction	Keyword concatenated	string concatenation	{"value": "%' OR 1=1 -- "}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
4	Query Construction	Final SQL created	SQL structure change	{"value": "%' OR 1=1 -- "}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
5	SQLite Parser	Final SQL parsed	SQL parsing	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
6	SQLite Execution	Read-only SELECT	local SQLite SELECT	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
7	Result Set	Condition compared	result comparison	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
8	HTTP Response	Results rendered	safe rendering	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data
9	Final Result	Security verdict	security verdict	{"value": "[observed]"}	{"decision": "unexpected_results", "error_c..."}	vulnerable_queries.py	observed	SQL structure is not isolated from data

Phụ lục Trace 9. Secure search

Trace ID: 9b0a0f174a1445f498db308da2bfc5dd · Mode: secure · Feature: search · Decision: expected_results

Field	Observed value	Field	Observed value
Mục tiêu	Chứng minh LIKE parameter giữ nguyên cấu trúc và giới hạn kết quả.	Điều kiện đầu	Database seed local; fixed scenario; SELECT-only.
Input	%' OR 1=1 --	Request	Method: GET Full URL: http://127.0.0.1:5005/secure/search?keyword=%25'+OR+1%3D1+--+ Path: /secure/search Query string: keyword=...
Source/normalize	request.args -> %' OR 1=1 --	Query template	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE ? LIMIT 50
Construction	parameter_binding	Final query masked	SELECT id, name, category, price_vnd, stock FROM products WHERE visible = 1 AND name LIKE ? LIMIT 50
SQLite	data	Rows	0
Decision	expected_results	Response	HTTP status: 200 Content-Type: text/html; charset=utf-8 Content-Security-Policy: default-src 'self'; script-src 'self'; style-s...
State change	database_modified=False	Root cause	none observed
Impact	expected local result	Code vulnerable/secure	secure_queries.py
Bản vá	Dùng SQL template + parameter binding; login secure tách PBKDF2 verification.	Trace JSON	9b0a0f174a1445f498db308da2bfc5dd
Audit event	{"action":"secure_search_completed","decision":"expected_results","reason":"parameter_binding_preserved_query_structure", "...	Final verdict	{"feature":"search","mode":"secure","input_category":"fixed_test","query_construction":"parameter_binding","sql_structure_ch ang...

Trace table - các bước quan sát được

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Browser UI	Keyword submitted	query string submission	{"value": "%' OR 1=1 --"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
2	Input Validation	Keyword validated	trust-boundary validation	{"value": "[observed]"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
3	Query Construction	LIKE parameter created	value transformation	{"value": "%' OR 1=1 --"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
4	Query Construction	Parameter bound	parameter binding	{"value": "%' OR 1=1 --"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
5	SQLite Execution	Structure preserved	parameterized SELECT	{"value": "[observed]"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
6	Result Set	Expected rows retained	result comparison	{"value": "[observed]"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data
7	Final Result	Security verdict	security verdict	{"value": "[observed]"}	{"decision": "expected_results", "erro r_cat...	secure_queries.py	observed	Input remains data